Can SOC Operators Explain their Decisions while Triaging Alarms? A Real-World Study (Supplementary Material)

Jessica Moosmann[1], Irdin Pekaric[1], and Giovanni Apruzzese[21]

[1] University of Liechtenstein, Vaduz, Liechtenstein
[2] Reykjavik University, Reykjavik, Iceland

Abstract. Security Operations Centers (SOCs) are pivotal in modern enterprises. Tasked to monitor complex network environments constantly under attack, SOCs can be active 24/7 and can include hundreds of operators supported by state-of-the-art technologies. Abundant research has studied the internal processes of SOCs, highlighting their pros and cons, as well as the challenges faced by SOC analysts—such as dealing with the overwhelming number of false alarms triggered by automated security mechanisms. In this context, we wonder: given that "someone" must triage the alarms, and that such triaging must be grounded on established knowledge or evidence-based reasoning, *can SOC employees justify why a certain decision was taken while triaging alarms?* Answering such a research question (RQ) can better guide future efforts.

We hence tackle this RQs. First, via a systematic literature review across 257 research documents, we provide evidence that such RQ received limited attention so far. Then, we partner-up with a real-world SOC and carry out a field study (n=12) with SOC employees. We show them real alarms raised in their SOC, and inquire whether such alarms are indicative of true security problems or not. Then, we ask to explain their decision. We found that while most analysts were able to separate "true from false" alarms (the decision was correct in 83% of the cases), a correct justification was hardly provided (only 39% of the provided explanations reflected the actual root cause). Ultimately, our results highlight the need for decision-support systems that help SOC analysts not only make the right call—but also understand and articulate *why* it is right.

Description

This document extends our main paper. Specifically, we report here: low-level results on our systematic literature review (discussed in Section 2 of our paper); a detailed description of our six considered cases (summarized in Section 4 of the paper); and we also report the complete questionnaire which we asked our participants to fill out (both before and after the study).

1 Results of our Systematic Literature Review

We report in Table 1 the full results of our systematic literature review, discussed in Section 2.2 of our main paper. Let us briefly explain how to read the table and how we classified each paper.

- The "SOC?" column denotes if the paper is specific about SOC. The decision was made independently by two authors and consensus was reached via discussion. For example, the work by Nadeem et al. [47] is a systematization of knowledge that, despite dealing with themes also relevant for SOC, is not specific to SOC (✗); similarly, Liu et al. [39] consider a SOC-related problem (explainability of IDS results) but there is no operational SOC knowhow integrated in the paper and even the subjects are not actual members of any SOC (✗). In contrast, we deemed the study by Kersten et al. [31] as ✓ because SOC analysts played an important role in the study's outcome.
- For "User Study Type", we report ✗ if there is no user study carried out in the paper. Otherwise, we report the type of user study, differentiating between interviews, surveys, field study (e.g., having participants carry out some exercise and then drawing conclusions, potentially after some follow-up interviews), or mixed-methods that combine surveys and interviews.
- For "Pop size", we report the number of participants of the user study. In cases where multiple studies were carried out, we report two numbers (e.g., for the study in [72], there was a survey done with 19 students and interviews done with three security experts). Cases with "?" indicate papers for which we were unable to find the exact number of participants (e.g., [35]).
- For "Participants", we report essential details of participants demographics, namely, their relatedness to cybersecurity. For instance, "student" typically denotes someone with no professional experience in security; "security professional" is a generic term indicating someone who works in a security-related role; "security analyst" typically denotes someone with technical expertise; "security expert" indicates someone that has experience in security, but not necessarily is employed in a security-related role; "security researcher" indicates someone who not necessarily has industry experience. In general, we used the most specific term reported in the corresponding paper to determine what to report in this column. We use "SOC" only if explicitly mentioned that (some) participants worked (or had worked) in an SOC.

We mention some intriguing findings. First, we have reason to believe that some studies are discussed in multiple papers (E.g., [16, 17], or [82, 81]). Some user studies only involved a single participant (E.g., [39]). For some studies, the exact number of participants was not reported [8, 35], whereas in [64] it was simply stated that interviews were carried out in a SOC of 20 members.

In terms of quantitative results, out of 74 peer-reviewed papers, 19 (25.6%) do not carry out any user study (despite mentioning an "user study"-related term in the text) and 28 (37.8%) are not very specific of SOC (despite mentioning an "SOC"-related term in the text). Among the 55 papers that carry out user studies, 39 (71%) specifically consider a SOC context. Across these 39, we computed an average of 14.42 participants across the 21 papers that carried out

only interviews and which reported the specific number of participants; whereas, for the four papers carrying out only surveys (with an explicit number of participants), the average population size is 133.75; whereas a total of four field studies were carried out, with an average number of participants of 11.75 (note that we found no number of participants for [35], and we counted [82, 81] only once).

Altogether, these findings confirm that field studies are very hard to carry out, as finding suitable participants for these types of research works is challenging. Note that, in the study described in our paper, n=12.

2 Case Study Definition

The practical exercise included six scenarios which we call *Cases* that had to be worked on by the participating analysts. These cases were based on real data sets from the company context and were selected with the aim of presenting scenarios that were as realistic as possible. Each case contained between 1 and 15 pre-correlated alarms that required further analysis and evaluation.
This six cases included both, true positives and false positives. The aim was to simulate realistic analysis activities and at the same time to analyse the participants' assessment skills in dealing with security-related alarms. As part of the preparation, the false positives were also divided into two categories for a more precise analysis: trivial false positives and relevant false positives. This distinction should make it possible to make differentiated statements about whether and to what extent certain false alarms have an impact on the analysis processes and decisions of the analysts, for example through unnecessary effort or potential uncertainty. The cases were carefully designed, categorised and each provided with pre-defined indicators that allow an objective classification as a true positive or a false positive. These indicators are based on the respective alarm types, the context of the events and additional information from the log and infrastructure perspective. In the original version of the study, real IP addresses were used in order to make the analysis as practical as possible. As this is sensitive and internal company information, it is not mentioned in this study in order to comply with data protection guidelines and to enable publication.

2.1 Case 1: Network scan by internal system

The first Case comprises a series of 15 correlated alarms that were triggered by an unusually high number of connection attempts from a single internal source IP address to a large number of different services. A total of 2,034 events were logged in the SIEM within a period of four hours. This behavior corresponds to typical patterns of a port or service scan [76]. The affected IP address was identified as an internal Nessus server using the central asset database. Nessus is a widely used security tool for automated vulnerability assessment that performs regularly scheduled scans within the IT infrastructure to identify potential security risks [51]. However, without the appropriate context, these scanning activities could be misinterpreted as malicious behavior. The case was therefore categorised in

Table 1: **Systematic Literature Review results.**

Paper (1st author)	**Year**	**SOC?**	**User Study Type**	**Pop size**	Participants description
Campobasso [18]	2023	✗	✗	✗	✗
Bostrom [14]	2025	✗	✗	✗	✗
Sai [59]	2024	✗	✗	✗	✗
Roul [55]	2025	✗	interview	42	incident management practitioners
Ashfaq [11]	2023	✗	survey	210	security professionals
Chowdhury [20]	2021	✗	survey	160	security professionals
Ikegwu [29]	2025	✗	✗	✗	✗
Tellenbach [67]	2019	✗	✗	✗	✗
Ulmer [72]	2019	✓	survey, interview	19, 3	students, security experts
Umayya [73]	2024	✗	✗	✗	✗
Majekodunmi [41]	2025	✗	interview	89	security leaders
Zhong [82]	2017	✓	field study	30	security analysts
Pettersen [52]	2024	✓	interview	8	professionals
Mavzeika [43]	2025	✗	✗	✗	✗
Fung [25]	2025	✓	interview	18	practitioners
Burda [17]	2025	✗	interview	49	university employees
Yamagishi [77]	2025	✓	interview	15	malware analysts
Ahmad [5]	2021	✓	interview	6	professionals & SOC analysts
Badva [12]	2024	✗	interview	22	threat hunters
Saganowski [57]	2020	✓	✗	✗	✗
Ahmad [4]	2020	✓	interview	6	SOC analysts
Malik [42]	2025	✗	survey	65	social-media users
Burda [16]	2024	✗	interview	49	generic employees
Araujo [10]	2025	✗	field study	32	authors of research papers
Kulikauskaite [35]	2025	✓	field study	?	SOC professionals
Finke [24]	2018	✗	survey	6	air traffic controllers
Saha [58]	2025	✓	mixed	15	experts with SOC experience
Apruzzese [9]	2023	✗	interview	12	security experts
Tundis [71]	2022	✓	interview	30	security experts and researchers
Memon [45]	2025	✗	interview	15	security experts
Sharma [61]	2025	✓	survey	300	?
Vermeer [75]	2022	✓	interview	7	security professionals
Zahid [78]	2025	✗	✗	✗	✗
Vermeer [74]	2023	✓	interview	17	SOC analysts
Afzalisesht [2]	2020	✗	✗	✗	✗
Kurogome [36]	2019	✓	survey	15	SOC analysts
Nair [48]	2025	✓	interview	?	security professionals
Sopan [62]	2018	✓	interview	5	SOC analysts
Zidan [83]	2024	✓	interview	10	professionals (not only security)
Ngwu [50]	2025	✓	interview	5	SOC professionals
Femi-Oyewole [23]	2024	✓	✗	✗	✗
Schiele [60]	2024	✓	interview	11	security and SOC professionals
Dietz [21]	2024	✓	✗	✗	✗
Hagen [28]	2025	✓	interview	19	security and SOC professionals
Teuwen [68]	2025	✓	✗	✗	✗
Zhong [80]	2025	✓	interview	24	security professionals
Liu [39]	2021	✗	survey	7	trainees (not professional analysts)
Tariq [66]	2025	✓	✗	✗	✗
Mink [46]	2023	✓	interview	18	security professionals
Nadeem [47]	2024	✗	✗	✗	✗
Alahmadi [6]	2022	✓	interview	21	SOC analysts
Eriksson [22]	2022	✓	interview	10	SOC analysts
Kokulu [34]	2019	✓	interview	18	SOC analysts
Kidmose [32]	2020	✗	✗	✗	✗
Lam [37]	2025	✓	interview	7	security professionals
Althobaiti [8]	2021	✗	interview	?	university members
Zhong [81]	2018	✓	field study	30	security analysts
Bouwman [15]	2020	✗	interview	14	security professionals
Sundarmurthy [64]	2015	✓	interview	(max 20)	SOC analysts
Reeves [54]	2025	✗	field study	10	experts
Saadallah [56]	2025	✓	interview	38	SOC analysts
Bhardwaj [13]	2019	✓	✗	✗	✗
Adnan [1]	2015	✓	survey	125	security professionals
Lerberknight [38]	2008	✗	✗	✗	✗
Gnanasekaran [27]	2025	✓	interview	10	security operators
Liu [40]	2024	✓	field study	1	SOC operators and students
Sundarmurthy [65]	2014	✓	field study	3	university students
McRee [44]	2022	✓	survey	95	security professionals
Agyepong [3]	2020	✓	✗	✗	✗
Kersten [31]	2024	✓	mixed	4, 57	SOC analysts, students
Jansen [30]	2024	✓	field study	13	SOC analysts
Stevens [63]	2022	✓	mixed	13	SOC professionals
Naseer [49]	2023	✓	interview	15	security and SOC professionals
Reeves [53]	2023	✓	interview	4	experts from industry and academia
Paper (1st author)	**Year**	**SOC?**	**User Study Type**	**Pop size**	Participants

advance as a trivial false positive, provided that the context information from asset management is available and taken into account during the analysis. If this information is missing or not included, the case could be incorrectly assessed as a true positive, and therefore it could be categorised as a relevant false positive. As part of the study, all participants had access to the central database and were therefore could be able to categorise the system role correctly (see table 2)

Table 2: Key data for Case 1

Attribute	**Description**
Category	False Positive – trivial (with context) / relevant (without context)
Number of Alerts	15
Logged Events	2,034 over a 4-hour period
Alert Type	Port scanning / suspicious network activity
Key Observables	IP source, IP destination, hit count, firewall action
Source	Internal IP address (Nessus server)
Action	Accept (connection allowed)
Indicator	System role identified in central asset database

2.2 Case 2: Legitimate developer activity triggering security alerts

The second Case includes four correlated alarms relating to various outgoing connections from internal IP addresses to external destinations. The associated systems are located in the same internal network segment. A total of 1,340 events were logged in the SIEM over a two-day period. All connections were accepted by the firewall. Observables include IP sources and destinations, protocols, hit count, firewall action, and classifications such as category (e.g. *Web Service Provider*, *Computer/Internet Activities*) and properties that allow conclusions to be drawn about the type of activity, including file sharing, instant messaging, encrypted communication, and software download. From a technical perspective, the observed network traffic can initially be interpreted by an analyst as legitimate and ordinary Internet traffic. However, on closer inspection, it becomes clear that the business context plays a central role in the assessment. There are clear internal guidelines within the company that prohibit certain types of communication and data transfer. These include, for example, the use of instant messaging services from unknown sources, the downloading of software, and the exchange of data via unauthorised platforms. Accordingly, this is unauthorised traffic which, despite its harmless technical appearance, must be classified as security-relevant in the specific corporate context. However, this is a trivial false positive (see Table 3) because activities are covered by an explicitly defined firewall rule for the development team, which allows exceptions to otherwise applicable security policies. The aim of this rule is to give developers access to certain external services and downloads that are necessary for their work. This connection could be verified by the raw data in the central log management system, in which the triggering firewall rule was logged. There, it was clearly evident that the connections were authorized by the named *developer rule*.

Table 3: Key data for Case 2

Attribute	**Description**
Category	False Positive – trivial
Number of Alerts	4
Logged Events	1,340 over a 2-day period
Alert Type	Outbound connections from internal IPs
Key Observables	IP source, IP destination, hit count, protocol, firewall action, category, properties
Source	Internal IPs from developer network segment
Action	Accept (connection allowed)
Indicator	Triggered by a specific developer firewall rule

2.3 Case 3: Outbound communication to Command & Control

The third Case deals with a security-critical event in which a single alarm and two associated log entries were registered in the SIEM over a 10-hour period. The affected connection was actively blocked by the firewall with the *Prevent* action, which in this context means that the connection attempt was not only recognized, but also immediately technically prevented. This is a proactive measure to protect against possible attacks or data outflows. The most important observables include the source and destination IP, the hit count, the selected firewall action and the, named by the system, *Malware Action*. The latter is particularly informative as it describes the alarm type in more detail. In this case, the alarm was triggered with the note *Communication with Command & Control (C&C)*. Such an indicator points to the possibility that a compromised system in the internal network has attempted to establish a connection to an external control server, a common pattern with botnets or advanced persistent threats (APT) [26]. The case is given additional relevance by the description in the alert text: *Connection to DNS trap bogus IP*. This is a reference to a *DNS sinkhole*, a security method in which known, malicious domain names are deliberately redirected to a controlled, invalid or unreachable IP address. The aim of a DNS sinkhole is to recognize malicious connections at an early stage, redirect them and thus make them visible. As soon as an infected system attempts to communicate with a known malicious domain, the request is intercepted by the sinkhole, which in this case led to an alert [33]. Even though Malware Action and DNS Sinkhole already provide strong indications, the target IP, the addressed service and the resolved DNS name were also checked as part of the analysis. The information contained in the raw data (SIEM) showed that the connection led to a website that was clearly classified as suspicious by external security services (e.g. URL analysis platforms). In the overall view of all indicators, Case 3 is a clear true positive. The alarm signals a real attack attempt or at least a compromised endpoint in the internal network that specifically wanted to communicate with a known C&C infrastructure (see table 4).

2.4 Case 4: Windows Internet connectivity check

Another scenario, Case 4 consists of two correlated alarms resulting from outgoing HTTP and HTTPS connections from an internal system to two different

Table 4: Key data for Case 3

Attribute	**Description**
Category	True Positive
Number of Alerts	1
Logged Events	2 over a 10-hour period
Alert Type	Outbound connection to Command & Control server
Key Observables	IP source, IP destination, hit count, firewall action, malware action
Source	Internal host
Action	Prevent (connection actively blocked)
Indicator	Description indicates DNS trap; malware action confirms C&C activity

external addresses. Within 24 hours, 31,518 corresponding events were recorded in the SIEM. The observables recorded included the source and destination IP, the protocol used, hit count and the action taken by the firewall. In all cases, the action was classified as *Pass*, which means that the data traffic was recognised but allowed in full, there was no blocking or technical restriction. In this case, the source system was an internal load balancer that acts as a proxy for downstream systems. The connection was targeted at *msftconnecttest.com*, a legitimate Microsoft website used by default by Windows systems to check the Internet connection. This typically involves retrieving a file called *connecttest.txt* to determine whether a connection to the Internet exists. This behavior is completely normal and occurs as soon as a device establishes a new network connection. Although this is legitimate traffic, some firewalls or security systems will hit this access, especially if it includes an HTTP redirect. Such redirects are generally considered suspicious, as they are often associated with malware infections or phishing activities. In fact, redirect behavior is one of the most common characteristics of compromised communications [19]. In this case, however, it is a deliberate redirect by Microsoft that poses no risk whatsoever. Accordingly, alerts of this type are misleading if viewed without contextual information. The evaluation as a false positive is based on several technically comprehensible indicators (see table 5). These include the known target URL (msftconnecttest.com), the typical retrieval of the file connecttest.txt, the presence of an HTTP redirect and the fact that access from Microsoft systems takes place by default for the purpose of connectivity checks. In addition, a *Whois* query of the external IP address shows that it is clearly assigned to Microsoft. The combination of these characteristics speaks against a threat situation, which is why the alert is not classified as security-relevant and is categorised as a trivial false positive for us.

Table 5: Key data for Case 4

Attribute	**Description**
Category	False Positive – trivial
Number of Alerts	2
Logged Events	31,518 within the last 24 hours
Alert Type	Outbound HTTP/HTTPS traffic to connectivity check URL
Key Observables	IP source, IP destination, hit count, protocol, firewall action
Source	Internal load balancer
Action	Pass (connection allowed)
Indicator	Access to msftconnecttest.com for Windows internet connectivity check, including HTTP redirect

2.5 Case 5: Dropped Retransmit WiFi

The Case 5 consists of a single alarm that is documented in the SIEM by two associated log entries over a period of two hours. The observed parameters include the source and destination IP address, the number of connection attempts (hit count), the protocol number, the reporting system (detected host), the associated domain and the specific reason for the trigger (reason). The endpoint protection evaluates the incident with the action *Block*, which means that the file is quarantined. A *Dropped Retransmit* is given as the reason for the alarm. This is a specific pattern in network traffic in which a packet that is retransmitted is not accepted or is discarded by the target system [70]. Retransmissions are a part of the TCP protocol and occur when a previously sent packet has not been acknowledged within a certain period of time. In this case, the sending system assumes that the packet has been lost and retransmits it. A *Dropped Retransmit* occurs when this retransmitted packet is not processed by the target system, for example, because it has already received a replacement packet or because it considers the connection to be inconsistent [69]. Such patterns can be interpreted as potentially malicious in certain security rules, as they can occur in attacks aimed at obfuscating or disrupting connections, among other things [79]. However, a more detailed analysis shows that the source IP is a dynamically assigned internal address from a WiFi area, while the destination address represents an internal file server. The comparison with the central asset database proves that the source is a mobile device that was temporarily connected to the WiFi. In wireless networks, it is not uncommon for the connection to drop out for short periods, for example when the device moves or in the event of temporary interference. In such situations, a sent data packet cannot be transmitted completely or is lost [7]. Nevertheless, the observed pattern, viewed in isolation, leads to an alarm, as it resembles a typical signature for suspicious communication. However, the correct assessment requires an understanding of network mechanisms, especially in the interaction of TCP protocol, IP assignment and WiFi connection dynamics. For this reason, the alarm was categorised as a relevant false positive in this investigation (see table 6). Although this is not a security-critical incident, the correct categorisation requires special technical expertise.

Table 6: Key data for Case 5

Attribute	**Description**
Category	False Positive – relevant
Number of Alerts	1
Logged Events	2 within a 2-hour period
Alert Type	Internal retransmission pattern classified as malicious
Key Observables	IP source, IP destination, hit count, protocol number, detected host, domain, action, reason
Source	Internal dynamically assigned WiFi IP
Action	Block (connection denied)
Indicator	IP Source is a WiFi IP

2.6 Case 6: Malicious PowerShell script executed by external user

Finally, Case 6 contains a single alarm that was triggered by the endpoint protection of a system itself. The affected host and the reporting system (detected host) are identical, it is therefore a self-report in which the protection software of the affected device has independently recognized a potential threat. In this case, two related entries were registered in the SIEM within a period of 20 hours. The relevant observables include the affected user, the host name, the associated domain, the hit count, the triggered label and the reason, which is the description of the specific threat. In this case, the label clearly identifies the incident as a *Virus*. The reason indicates which specific file was affected, in this case a PowerShell script with a conspicuous file name that already looks suspicious without deeper analysis. The user under whom the incident occurred deserves special attention. From the user name, it can be deduced that it is an external user account. This is recognisable by a specific naming convention that is used within the company. This knowledge is not directly apparent from the raw data, but requires knowledge of the internal guidelines for user administration. Endpoint protection successfully blocked the script and automatically moved it to quarantine, preventing it from being executed. Due to the combination of suspicious file name, identification by the protection software, confirmed blocking and execution by an external account, the incident can be classified as a real threat. In the overall assessment, Case 6 is clearly a True Positive (see table 7), as both technical indicators and contextual information point to a successful protection mechanism against a malicious PowerShell script that should not have been executed under any circumstances.

Table 7: Key data for Case 6

Attribute	**Description**
Category	True Positive
Number of Alerts	1
Logged Events	2 within a 20-hour period
Alert Type	Endpoint protection alert triggered by suspicious PowerShell script
Key Observables	Hit count, detected host, host, domain, user, label, reason
Source	Endpoint (self-reported)
Action	File blocked and quarantined
Indicator	Label indicates virus; reason specifies affected file; username reveals access via external account

3 Questionnaires

We report in this Appendix the complete pre- (Table 8) and post-study (Table 9) questionnaires. We observe that, for the latter, we also requested (asynchronous) feedback to participants (via email).

Table 8: Introductionary Questionnaire

No.	Question	Possible Answers	Man.	Dyn.	Purpose
1	Do you agree to participate in this study and give informed consent?	Yes; No	Yes	No	Ensures participants voluntarily agree to the study, acknowledges anonymity, and confirms their right to withdraw data at any time.
2	What is your highest educational qualification?	No degree; high school diploma; vocational training; higher technical school; Bachelor; Master; PhD; other	Yes	No	Captures participants' education level to analyse correlations with analytical depth and communication quality in SOC work.
3	Have you completed an apprenticeship or degree in an IT or security-related field?	Yes (IT-oriented); Yes (security-oriented); No (unrelated); Other	Yes	No	Identifies relevant technical background influencing ability to analyse and understand security incidents.
4	How long have you been working as a SOC analyst?	<1 year; 1–3 years; 3–5 years; 5–10 years; >10 years	Yes	No	Captures SOC-specific practical experience that influences incident-handling performance.
5	How many years of professional experience do you have in the IT sector?	<6 months; 6–12 months; 1–3 years; 3–5 years; >5 years	Yes	No	Refines general IT experience to contextualise SOC expertise beyond analyst years.
6	Which IT areas did you familiarise yourself with before your current job? (multiple choice)	Network/Infrastructure; Software development; System administration; IT support; Pentesting/Red teaming; IT security training; Other	Yes	No	Maps prior technical exposure that shapes how analysts understand and investigate security incidents.
7	How would you rate your current knowledge of IT security and SOC processes?	Beginner; Basic knowledge; Advanced (specific areas); Advanced (broad); Expert	Yes	No	Captures subjective competence for comparison with actual performance and confidence levels.
8	Which IT security tools have you already worked with? (multiple choice)	SIEM; IDS/IPS; EDR; Firewalls; Packet capturing tools; Threat intelligence platforms; Other	Yes	No	Identifies hands-on experience with tools central to SOC workflows.
9	Do you have experience in log analysis?	Yes; No	Yes	Yes (→9a)	Determines experience in one of the core analysis activities in SOC environments.
9a	Which log types have you already gained experience with? (multiple choice)	Windows logs; Firewall logs; Web server logs; EDR logs; Proxy logs; Authentication logs; Other	Yes	No	Identifies breadth and depth of log-analysis experience.
10	How confident do you feel when interpreting security-related messages (e.g., in SIEM)?	1–5 Stars	Yes	No	Measures analysts' self-perceived confidence in interpreting alerts.
11	How do you typically go about analysing a security alert?	Open question	Yes	No	Captures personal workflow, thought process, and procedural structure during analysis.
12	What information do you use first to evaluate an alarm?	Open question	Yes	No	Identifies which data sources analysts prioritise for triage and early false-positive filtering.
13	Apart from the information you check first: how do you determine if an alarm is a false positive?	Open question	Yes	No	Reveals deeper evaluation steps beyond initial triage, including verification strategies and contextual checks.
14	How confident are you in your ability to correctly recognise and assess false positives?	1–5 Stars	Yes	No	Measures confidence in distinguishing true security events from benign behaviour.
15	What do you do if you are unsure about an alarm? (multiple choice)	Research yourself; Ask colleagues; Check other logs; Compare with playbooks/runbooks; Create and forward ticket; Other	Yes	No	Captures uncertainty-handling strategies, illustrating independence vs. collaboration.
16	Are there certain types of alarms or situations that you find particularly challenging?	Open question	Yes	No	Identifies perceived difficulty areas in alarm handling, highlighting stress points or technical weaknesses.
17	Do you rely on artificial intelligence methods to perform your tasks as a SOC analyst?	Yes (certainly); Rather yes (not sure); Rather no (not sure); No (certainly not)	Yes	No	Captures analysts' awareness, confidence, and perception of AI-supported SOC tooling.

Table 9: Final Questionnaire

No.	Question	Possible Answers	Man.	Dyn.	Purpose
1	Do you agree to participate in this study and give informed consent?	Yes; No	Yes	No	Ensures participants voluntarily agree to the study, acknowledge anonymity, and can withdraw data at any time.
2	What was your experience of analysing these alarms? (multiple choice)	Straightforward; Uncertain; Time-consuming; Hard to distinguish relevance; Identified incidents; Frustrating; Used structured procedures; Felt confident; Other	Yes	No	Captures subjective perceptions of difficulty, uncertainty, efficiency and confidence during the analysis task.
3	[Whd] How do you typically go about analysing security alerts?	Open question	No	No	Identifies whether the participant's analysis procedures changed after the practical exercise.
4	[Whd] What information do you consult first to evaluate an alarm?	Open question	No	No	Shows whether prioritisation of information sources shifted after the exercise.
5	[Whd] Apart from the first information: how do you determine if an alarm is a false positive?	Open question	No	No	Determines whether verification and decision-making strategies changed through practice.
6	[Whd] How confident are you in your ability to recognise false positives?	1–5 Stars	No	No	Measures whether confidence increased or decreased after the practical exercise.
7	[Whd] Are there alarm types or situations you find particularly challenging?	Open question	No	No	Shows whether perceived difficulty has changed compared to the introduction questionnaire.
8	For which alarms did you feel you took the right analysis path?	Open question	Yes	No	Identifies patterns and situations where participants felt competent and confident.
9	Were there any alarms that you are still not quite sure about?	Yes; No	Yes	Yes (→9a)	Captures remaining uncertainties after the completed exercise.
9a	What are you missing to make a final assessment?	Open question	Yes	No	Reveals missing data, insufficient context, or tool limitations.
10	Did you have to correct your original assessment afterwards?	Yes; No	Yes	Yes (→10a)	Identifies misjudgements and whether reflection or new information changed decisions.
10a	What was the trigger for this correction?	Open question	Yes	No	Shows causes such as new evidence, more context, or recognition of mistaken assumptions.
11	For which alarms were you able to reach a decision quickly?	Open question	Yes	No	Identifies cases where strong cues or familiar patterns supported rapid evaluation.
12	Why was it easy to recognise them? What data points or indicators helped?	Open question	Yes	No	Captures the decisive indicators, logs, or context that facilitated quick assessment.
13	Which alarms made you hesitate the longest or made you think the most?	Open question	Yes	No	Highlights complex situations with ambiguous or contradictory information.
14	What has made analysing these alerts more complicated?	Open question	Yes	No	Reveals structural, contextual, or technical barriers that hinder analysis.
15	What additional information would have helped you make a decision faster?	Open question	Yes	No	Shows missing data or context essential for efficient decision-making.
16	Did you have to actively search for additional information not included in the alarm?	Yes; No	Yes	Yes (→16a)	Captures whether participants needed external data beyond what the exercise provided.
16a	For which alarms did you have to search for this additional information?	Open question	Yes	No	Identifies which alarms lacked sufficient clarity or contextual detail.
17	Which alarms surprised you? Where did you check more than expected?	Open question	Yes	No	Reveals alarms where complexity or misleading indicators required deeper investigation.
18	Are there alarm types you would prefer to avoid if possible? Why?	Open question	Yes	No	Captures discomfort, stress factors, or cases perceived as overly ambiguous or demanding.

Bibliography

[1] Adnan, M., Just, M., Baillie, L., Kayacik, H.G.: Investigating the work practices of network security professionals. Information & Computer Security **23**(3), 347–367 (2015)

[2] Afzaliseresht, N., Miao, Y., Michalska, S., Liu, Q., Wang, H.: From logs to stories: human-centred data mining for cyber threat intelligence. IEEE access **8**, 19089–19099 (2020)

[3] Agyepong, E., Cherdantseva, Y., Reinecke, P., Burnap, P.: Challenges and performance metrics for security operations center analysts: a systematic review. Journal of Cyber Security Technology **4**(3), 125–152 (2020)

[4] Ahmad, A., Desouza, K., Maynard, S.B., Whitty, M., Kotsias, J., Baskerville, R.: Situation-awareness in incident response: an in-depth case study and process model. In: ICIS (2020)

[5] Ahmad, A., Maynard, S.B., Desouza, K.C., Kotsias, J., Whitty, M.T., Baskerville, R.L.: How can organizations develop situation awareness for incident response: A case study of management practice. Computers & Security **101**, 102122 (2021)

[6] Alahmadi, B.A., Axon, L., Martinovic, I.: 99% false positives: A qualitative study of {SOC} analysts' perspectives on security alarms. In: 31st USENIX Security Symposium (USENIX Security 22), pp. 2783–2800 (2022)

[7] Allman, M., Paxson, V.: On making tcp robust against spurious retransmissions. In: Proceedings of the ACM SIGCOMM, pp. 231–241, ACM (2000), https://doi.org/10.1145/347057.347407

[8] Althobaiti, K., Jenkins, A.D., Vaniea, K.: A case study of phishing incident response in an educational organization. Proceedings of the ACM on Human-Computer Interaction **5**(CSCW2), 1–32 (2021)

[9] Apruzzese, G., Laskov, P., Schneider, J.: Sok: Pragmatic assessment of machine learning for network intrusion detection. In: 2023 IEEE 8th European Symposium on Security and Privacy (EuroS&P), pp. 592–614, IEEE (2023)

[10] Araujo, I., Vieira, M.: Enhancing intrusion detection in containerized services: Assessing machine learning models and an advanced representation for system call data. Computers & Security **154**, 104438 (2025)

[11] Ashfaq, S., Biswas, S., Chowdhury, T.K.: Integration of artificial intelligence and advanced computing to develop resilient cyber defense systems. Journal of Sustainable Development and Policy **2**(04), 74–107 (2023)

[12] Badva, P., Ramokapane, K.M., Pantano, E., Rashid, A.: Unveiling the {Hunter-Gatherers}: Exploring threat hunting practices and challenges in cyber defense. In: 33rd USENIX Security Symposium (USENIX Security 24), pp. 3313–3330 (2024)

[13] Bhardwaj, A., Goundar, S.: A framework for effective threat hunting. Network Security **2019**(6), 15–19 (2019)

[14] Bostrom, S.R., LeValley, G.L., Cooley, K., Niemeyer, R.E.: Open science is coming to theory construction: The case of document analysis. Qualitative Report **30**(8) (2025)

[15] Bouwman, X., Griffioen, H., Egbers, J., Doerr, C., Klievink, B., Van Eeten, M.: A different cup of {TI}? the added value of commercial threat intelligence. In: 29th USENIX security symposium (USENIX security 20), pp. 433–450 (2020)

[16] Burda, P., Allodi, L., Serebrenik, A., Zannone, N.: 'protect and fight back': A case study on user motivations to report phishing emails. In: Proceedings of the 2024 European Symposium on Usable Security, pp. 30–43 (2024)
[17] Burda, P., Allodi, L., Serebrenik, A., Zannone, N.: Phishing reporting in organizations: What motivates employees to take action? Information & Computer Security pp. 1–28 (2025)
[18] Campobasso, M., Allodi, L.: Know your cybercriminal: Evaluating attacker preferences by measuring profile sales on an active, leading criminal market for user impersonation at scale. In: 32nd USENIX Security Symposium (USENIX Security 23), pp. 553–570 (2023)
[19] Chen, Z., Freire, J.: Discovering and measuring malicious url redirection campaigns from fake news domains. In: 2021 IEEE Security and Privacy Workshops (SPW) (2021), https://doi.org/10.1109/SPW53761.2021.00008
[20] Chowdhury, T.K., Biswas, S.: Blockchain-enabled security protocols combined with ai for securing next-generation internet of things (iot) networks. International Journal of Scientific Interdisciplinary Research **2**(2), 98–127 (2021)
[21] Dietz, K., Mühlhauser, M., Kögel, J., Schwinger, S., Sichermann, M., Seufert, M., Herrmann, D., Hoßfeld, T.: The missing link in network intrusion detection: Taking ai/ml research efforts to users. IEEE Access **12**, 79815–79837 (2024)
[22] Eriksson, H.S., Grov, G.: Towards xai in the soc–a user centric study of explainable alerts with shap and lime. In: 2022 IEEE International Conference on Big Data (Big Data), pp. 2595–2600, IEEE (2022)
[23] Femi-Oyewole, F., Osamor, V., Okunbor, D.: Ensemble machine learning approach for identifying real-time threats in security operations center. IAENG International Journal of Computer Science **51**(12) (2024)
[24] Finke, M., Stelkens-Kobsch, T.H.: A practical example for validation of atm security prototypes. CEAS Aeronautical Journal **9**(1), 157–170 (2018)
[25] Fung, C., Zeng, E., Bauer, L.: Adopting {AI} to protect industrial control systems: Assessing challenges and opportunities from the {Operators'} perspective. In: Twenty-First Symposium on Usable Privacy and Security (SOUPS 2025), pp. 555–573 (2025)
[26] Gardiner, J., Cova, M., Nagaraja, S.: Command & control: Understanding, denying and detecting - a review of malware c2 techniques, detection and defences. arXiv preprint arXiv:1408.1136 (2014)
[27] Gnanasekaran, V., Fatima, U., Glas, M., Heegaard, P.E.: A model-based framework for developing security-safety incident response plans: V. gnanasekaran et al. International Journal of Information Security **24**(6), 229 (2025)
[28] Hagen, R.A., Øverlier, L., Helkala, K.: Human factors in ai-driven cybersecurity: Cognitive biases and trust issues. Digital Threats: Research and Practice **6**(4), 1–20 (2025)
[29] Ikegwu, A.C., Alo, U.R., Nweke, H.F.: Cyber threats in mobile healthcare applications: systematic review of enabling technologies, threat models, detection approaches, and future directions. Discover Computing **28**(1), 152 (2025)
[30] Jansen, M., Bobba, R., Nevin, D.: A comparative analysis of difficulty between log and graph-based detection rule creation. In: Workshop on SOC Operations and Construction (WOSOC) 2024 (2024)
[31] Kersten, L., Darré, S., Mulders, T., Zambon, E., Caselli, M., Snijders, C., Allodi, L.: A security alert investigation tool supporting tier 1 analysts in contextualizing and understanding network security events. In: 2024 Annual Computer Security Applications Conference (ACSAC), pp. 890–905, IEEE (2024)

[32] Kidmose, E., Stevanovic, M., Brandbyge, S., Pedersen, J.M.: Featureless discovery of correlated and false intrusion alerts. IEEE Access **8**, 108748–108765 (2020)
[33] Kim, H., Lee, J., Shin, K.: A methodology for multipurpose dns sinkhole analyzing double bounce emails. In: Proceedings of the International Conference on Network-Based Information Systems (NBiS), pp. 76–83, Springer (2011)
[34] Kokulu, F.B., Soneji, A., Bao, T., Shoshitaishvili, Y., Zhao, Z., Doupé, A., Ahn, G.J.: Matched and mismatched socs: A qualitative study on security operations center issues. In: Proceedings of the 2019 ACM SIGSAC conference on computer and communications security, pp. 1955–1970 (2019)
[35] Kulikauskaitė, K., Baranauskis, K.: Advancing cybersecurity competence assessment frameworks integrating human factor dimensions. In: DAMSS: 16th conference on data analysis methods for software systems, November 27–29, 2025, Druskininkai, Lithuania., Vilnius University Press (2025)
[36] Kurogome, Y., Otsuki, Y., Kawakoya, Y., Iwamura, M., Hayashi, S., Mori, T., Sen, K.: Eiger: automated ioc generation for accurate and interpretable endpoint malware detection. In: Proceedings of the 35th Annual Computer Security Applications Conference, pp. 687–701 (2019)
[37] Lam, T.K., Bongiovanni, I., Carthouser, B., Williams, J.: Future skills of a cybersecurity defence team. Information & Computer Security (2025)
[38] Leberknight, C.S., Widmeyer, G.R., Recce, M.L.: Decision support for perceived threat in the context of intrustion detection systems. AMCIS 2008 Proceedings p. 317 (2008)
[39] Liu, H., Zhong, C., Alnusair, A., Islam, S.R.: Faixid: A framework for enhancing ai explainability of intrusion detection results using data cleaning techniques. Journal of network and systems management **29**(4), 40 (2021)
[40] Liu, Y., Li, T., Zhang, R., Jin, Z., Tong, M., Liu, W., Wang, Y., Yang, Z.: A context-aware clustering approach for assisting operators in classifying security alerts. IEEE Transactions on Software Engineering (2024)
[41] Majekodunmi, A.O., Edohen, A., Conteh, J., Evans-Anoruo, U.: Regulatory divergence and security implementation: Compliance-driven security architecture in multi-jurisdictional financial organizations. Research Journal in Civil, Industrial and Mechanical Engineering (2025)
[42] Malik, A., Arshid, K., Noonari, N., Munir, R.: Artificial intelligence-driven cybersecurity framework using machine learning for advanced threat detection and prevention. Sch J Eng Tech **6**, 401–423 (2025)
[43] Mažeika, D., Volodka, D.: Correlation-based log data analysis for cybersecurity incident detection. In: 16th conference on data analysis methods for software systems (DAMSS), 27-29 November 2025, Druskininkai, Lithuania., Vilnius University press (2025)
[44] McRee, G.R.: Improved detection and response via optimized alerts: Usability study. Journal of Cybersecurity and Privacy **2**(2), 379–401 (2022)
[45] Memon, N.A., Sultana, M., Siddiqui, E.A.A., Murtaza, M.: Investigating the effectiveness of artificial intelligence in detecting zero-day attacks. Spectrum of Engineering Sciences pp. 804–817 (2025)
[46] Mink, J., Benkraouda, H., Yang, L., Ciptadi, A., Ahmadzadeh, A., Votipka, D., Wang, G.: Everybody's got ml, tell me what else you have: Practitioners' perception of ml-based security tools and explanations. In: 2023 IEEE Symposium on Security and Privacy (SP), pp. 2068–2085, IEEE (2023)
[47] Nadeem, A., Vos, D., Cao, C., Pajola, L., Dieck, S., Baumgartner, R., Verwer, S.: Sok: Explainable machine learning for computer security applications. In: 2023

IEEE 8th European Symposium on Security and Privacy (EuroS&P), pp. 221–240, IEEE (2023)

[48] NAIR, R.R.: Evaluating the effectiveness of ai-driven threat intelligence systems: A technical analysis. Journal of Computer Science and Technology Studies **7**(3), 514–524 (2025)

[49] Naseer, A., Naseer, H., Ahmad, A., Maynard, S.B., Siddiqui, A.M.: Moving towards agile cybersecurity incident response: A case study exploring the enabling role of big data analytics-embedded dynamic capabilities. Computers & Security **135**, 103525 (2023)

[50] Ngwu, N.F.: Key socio-organisational indicators that influence the level of integration of generative ai in security oper-ations centers: A socio-technical perspective. Ausgewählte Fragestellungen KI-getriebener Transformation p. 213 (2025)

[51] Pandit, P.D.: Nessus: Study of a tool to assess network vulnerabilities. Technical report, Mumbai University (2021), https://doi.org/10.13140/RG.2.2.14758.65604

[52] Pettersen, S., Grøtan, T.O.: Exploring the grounds for cyber resilience in the hyper-connected oil and gas industry. Safety Science **171**, 106384 (2024)

[53] Reeves, A., Ashenden, D.: Understanding decision making in security operations centres: building the case for cyber deception technology. Frontiers in Psychology **14**, 1165705 (2023)

[54] Reeves, A., Ashenden, D.: 'it's not paranoia if they're really after you': When announcing deception technology can change attacker decisions. In: HICSS (2025)

[55] Roul, S.: Incident management in b2b payments: Challenges, frameworks, and emerging best practices. Journal of Computer Science and Technology Studies **7**(11), 135–175 (2025)

[56] Saadallah, M., Shahim, A., Khapova, S.: Harmonizing paradoxical tensions in socs: A strategic model for integrating ai, automation, and human expertise in cyber defense and incident response. In: 58th Hawaii International Conference on System Sciences, HICSS 2025, pp. 6171–6180, University of Hawaii Press (2025)

[57] Saganowski, S.: A three-stage machine learning network security solution for public entities. In: 2020 IEEE 19th International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom), pp. 1097–1104, IEEE (2020)

[58] Saha, A., Mattei, J., Blasco, J., Cavallaro, L., Votipka, D., Lindorfer, M.: Expert insights into advanced persistent threats: Analysis, attribution, and challenges. In: Proceedings of the 34th USENIX Security Symposium (USENIX Sec) (2025)

[59] Sai, S., Yashvardhan, U., Chamola, V., Sikdar, B.: Generative ai for cyber security: Analyzing the potential of chatgpt, dall-e, and other models for enhancing the security space. IEEE access **12**, 53497–53516 (2024)

[60] Schiele, N.D., Egberts, J., Gadyatskaya, O.: Nobody knows the risks i have seen: Evaluating the gap between risk analysis and security operations. In: 2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), pp. 473–483, IEEE (2024)

[61] Sharma, A., Kumar, V.K., Poojari, A.: Prioritize threat alerts based on false positives qualifiers provided by multiple ai models using evolutionary computation and reinforcement learning. Journal of The Institution of Engineers (India): Series B **106**(4), 1305–1322 (2025)

[62] Sopan, A., Berninger, M., Mulakaluri, M., Katakam, R.: Building a machine learning model for the soc, by the input from the soc, and analyzing it for the soc. In: 2018 IEEE Symposium on Visualization for Cyber Security (VizSec), pp. 1–8, IEEE (2018)

[63] Stevens, R., Votipka, D., Dykstra, J., Tomlinson, F., Quartararo, E., Ahern, C., Mazurek, M.L.: How ready is your ready? assessing the usability of incident response playbook frameworks. In: Proceedings of the 2022 CHI Conference on Human Factors in Computing Systems, pp. 1–18 (2022)
[64] Sundaramurthy, S.C., Bardas, A.G., Case, J., Ou, X., Wesch, M., McHugh, J., Rajagopalan, S.R.: A human capital model for mitigating security analyst burnout. In: Eleventh symposium on usable privacy and security (SOUPS 2015), pp. 347–359 (2015)
[65] Sundaramurthy, S.C., Case, J., Truong, T., Zomlot, L., Hoffmann, M.: A tale of three security operation centers. In: Proceedings of the 2014 ACM workshop on security information workers, pp. 43–50 (2014)
[66] Tariq, S., Baruwal Chhetri, M., Nepal, S., Paris, C.: Alert fatigue in security operations centres: Research challenges and opportunities. ACM Computing Surveys **57**(9), 1–38 (2025)
[67] Tellenbach, B., Rennhard, M., Schweizer, R.: Security of data science and data science for security. In: Applied data science: lessons learned for the data-driven business, pp. 265–288, Springer (2019)
[68] Teuwen, K.T., Mulders, T., Zambon, E., Allodi, L.: Ruling the unruly: Designing effective, low-noise network intrusion detection rules for security operations centers. In: Proceedings of the 20th ACM Asia Conference on Computer and Communications Security, pp. 1428–1441 (2025)
[69] Tian, Y., Xu, K., Ansari, N.: Tcp in wireless environments: Problems and solutions. IEEE Transactions on Mobile Communications **4**(3), 184–192 (2005), https://doi.org/10.1109/TMC.2005.40
[70] Trend Micro: Deep security: Firewall events and alerts reference. https://help.deepsecurity.trendmicro.com/10/0/Events-Alerts/ref-events-firewall.html (2024), accessed: 2025-06-17
[71] Tundis, A., Ruppert, S., Mühlhäuser, M.: A feature-driven method for automating the assessment of osint cyber threat sources. Computers & Security **113**, 102576 (2022)
[72] Ulmer, A., Sessler, D., Kohlhammer, J.: Netcapvis: Web-based progressive visual analytics for network packet captures. In: 2019 IEEE Symposium on Visualization for Cyber Security (VizSec), pp. 1–10, IEEE (2019)
[73] Umayya, Z., Nandi, A., Roy, A., Chakravarty, S.: Every sherlock needs a watson: Practical semi-realtime attack elaboration system. In: International Conference on Network and System Security, pp. 277–300, Springer (2024)
[74] Vermeer, M., Kadenko, N., van Eeten, M., Gañán, C., Parkin, S.: Alert alchemy: Soc workflows and decisions in the management of nids rules. In: Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security, pp. 2770–2784 (2023)
[75] Vermeer, M., Van Eeten, M., Gañán, C.: Ruling the rules: Quantifying the evolution of rulesets, alerts and incidents in network intrusion detection. In: Proceedings of the 2022 ACM on Asia Conference on Computer and Communications Security, pp. 799–814 (2022)
[76] Vivo, M.D., Carrasco, E., Isern, G.O., Vivo, G.O.D.: A review of port scanning techniques. ACM SIGCOMM Computer Communication Review **29**(2), 41–48 (1999), https://doi.org/10.1145/571696.571700
[77] Yamagishi, R., Fujii, S., Yasuda, S., Sato, T., Hasegawa, A.A.: Collaborative work in malware analysis: Understanding the roles and challenges of malware analysts. In: Proceedings of the 2025 CHI Conference on Human Factors in Computing Systems, pp. 1–15 (2025)

[78] Zahid, I.A., Garfan, S., Chyad, M., Albahri, A., Albahri, O., Alamoodi, A., Deveci, M., Homod, R.Z., Alzubaidi, L.: Explainability, robustness, and fairness in user-centric intelligent systems: A systematic review. IEEE Transactions on Emerging Topics in Computational Intelligence (2025)

[79] Zhang, X., Wu, S.F., Fu, Z., Wu, T.L.: Malicious packet dropping: How it might impact the tcp performance and how we can detect it. In: Proceedings of the 8th International Conference on Network Protocols (ICNP), pp. 263–272, IEEE Computer Society (2000), https://doi.org/10.1109/ICNP.2000.895227

[80] Zhong, C., Yayla, A.: Cognitive impacts of explainable ai in cybersecurity incident response: Challenges and propositions. Information Systems Frontiers pp. 1–23 (2025)

[81] Zhong, C., Yen, J., Liu, P., Erbacher, R.F.: Learning from experts' experience: toward automated cyber security data triage. IEEE Systems Journal **13**(1), 603–614 (2018)

[82] Zhong, C., Yen, J., Liu, P., Erbacher, R.F., Garneau, C., Chen, B.: Studying analysts' data triage operations in cyber defense situational analysis. In: Theory and models for cyber situation awareness, pp. 128–169, Springer (2017)

[83] Zidan, K., Alam, A., Mirza, Q.A.: A grid-matrix based on industry needs to evaluate automation in security operations centre (soc). In: 2024 11th International Conference on Future Internet of Things and Cloud (FiCloud), pp. 16–20, IEEE (2024)